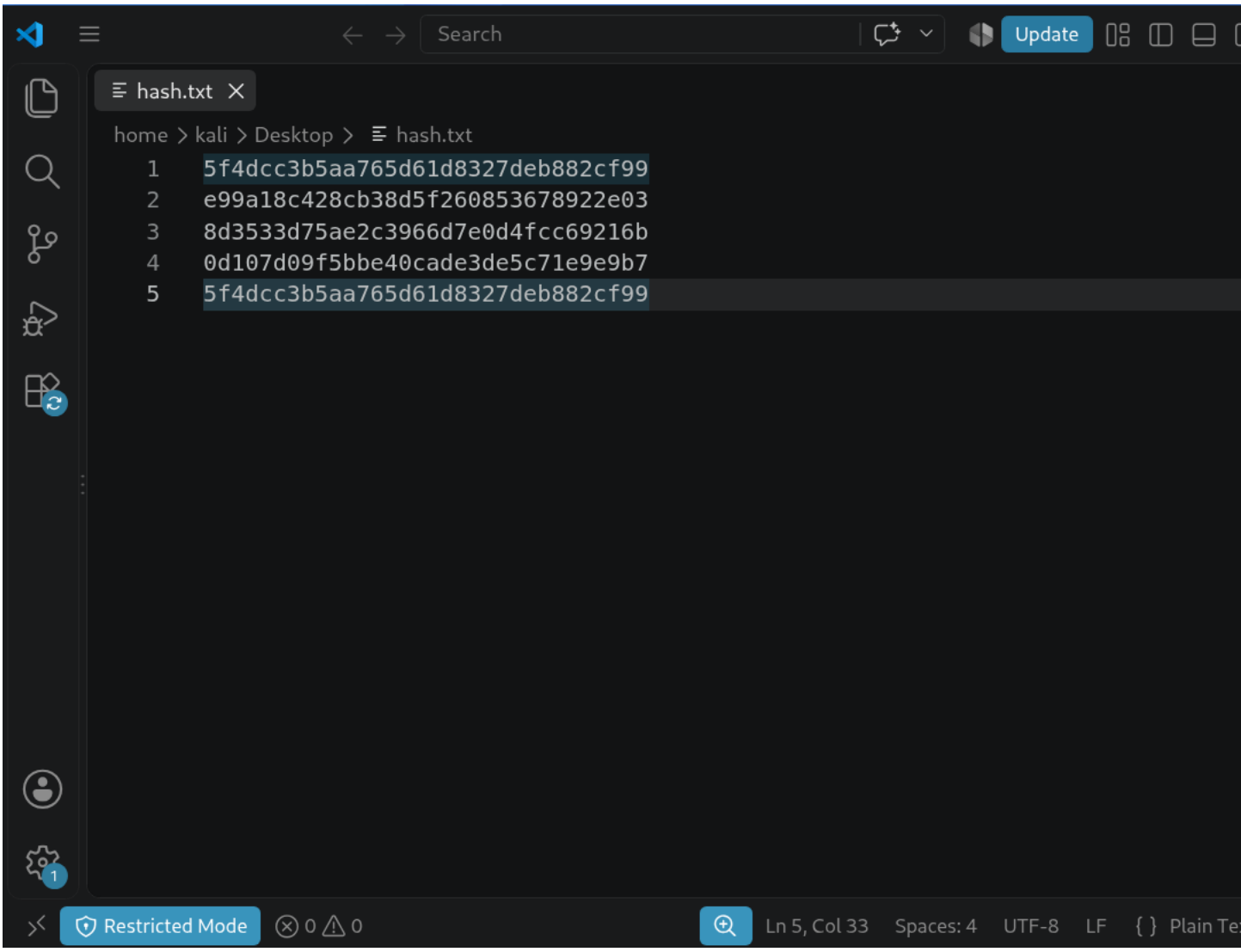
REPORT PASSWORD CRACKING CON JOHN THE RIPPER

1. Recupero degli hash tramite SQL Injection

In una precedente esercitazione è stata eseguita una vulnerabilità di SQL Injection che ha consentito di estrarre dal database gli hash delle password degli utenti.



Dall'analisi dei valori ottenuti è stato osservato che le password non erano memorizzate in chiaro, ma sotto forma di hash MD5.

2. Tipologia e meccanismo utilizzato per il cracking

Per recuperare le password in chiaro è stato utilizzato John the Ripper, uno strumento di password cracking disponibile in Kali Linux.

L'attacco eseguito è di tipo Dictionary Attack (attacco a dizionario).

Funzionamento:

L'attacco a dizionario consiste nel confrontare gli hash presenti nel file contenente le password con gli hash generati a partire da una lista di parole predefinite.

Per ogni parola presente nel dizionario:

John the Ripper genera l'hash MD5 della parola, Confronta l'hash generato con quelli presenti nel file da analizzare. Se viene trovata una corrispondenza, la password originale viene recuperata.

Nel test è stato utilizzato il famoso file rockyou.txt, che contiene milioni di password comuni utilizzate dagli utenti.

Comando utilizzato:

john --format=raw-md5 --wordlist=/home/kali/Desktop/rockyou.txt /home/kali/Desktop/hash.txt

Significato dei parametri:

john : avvia John the Ripper.

--format=raw-md5 : specifica che gli hash da analizzare sono di tipo MD5.

--wordlist=/home/kali/Desktop/rockyou.txt : indica il dizionario utilizzato per il cracking.

/home/kali/Desktop/hash.txt : file contenente gli hash recuperati dal database.

Al termine del processo è stato utilizzato il comando:

john --show --format=raw-md5 /home/kali/Desktop/hash.txt (per visualizzare le password recuperate)

3. Risultati ottenuti

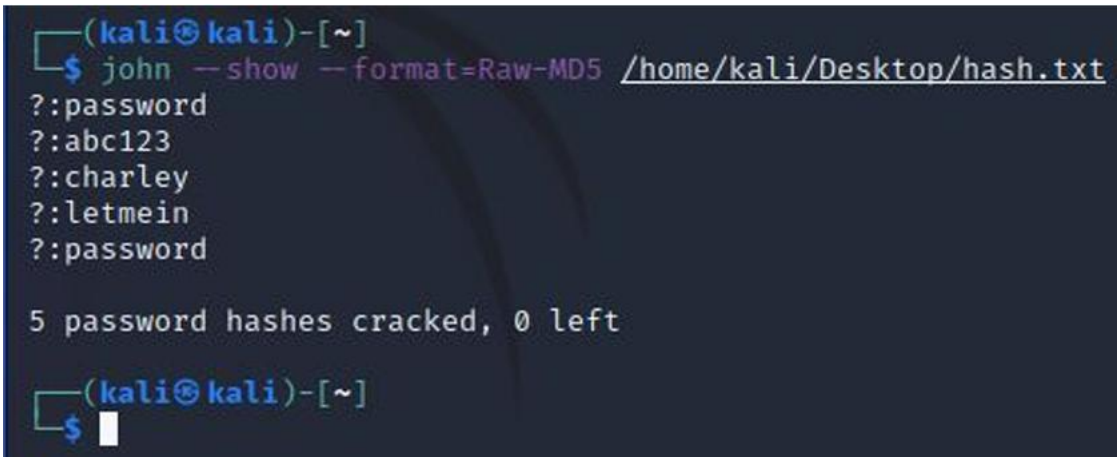
L'esecuzione di John the Ripper ha permesso di recuperare tutte le password presenti nel file degli hash.

Password trovate:

- Password
- abc123
- charley
- letmein
- password

Output finale: 5 password hashes cracked, 0 left

Ciò significa che tutti e 5 gli hash presenti nel file sono stati correttamente decifrati tramite l'attacco a dizionario.



Conclusioni

L'esercitazione ha dimostrato come password deboli e comuni possano essere recuperate facilmente mediante un attacco a dizionario. Utilizzando John the Ripper e il dizionario rockyou.txt è stato possibile identificare tutte le password associate agli hash MD5 recuperati tramite SQL Injection.

Questo evidenzia l'importanza di utilizzare password complesse e di adottare algoritmi di hashing più sicuri rispetto a MD5 per la protezione delle credenziali degli utenti.